

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking

COURSE CODE: ITA14

COURSE OUTCOME COVERED

CO2: Foot printing Tools: Conducting Competitive Intelligence, DNS Zone Transfers, Introduction to Social Engineering: Social Engineering Attacks and Countermeasures. (BT4)

Assessment Tool Weightage: 30%

Duration: 90 min

Total Marks: 50

Social Engineering Simulation

Questions

1. As a Security Analyst, perform an OSINT-based email enumeration assessment on the target domain **tesla.com** using **theHarvester** in Kali Linux. Collect publicly available email addresses, subdomains, hosts, and IP addresses associated with the organization. Categorize the discovered email addresses into likely roles such as Support, Sales, Human Resources, Administration, and Technical Teams. Analyze how the gathered information could assist an attacker during the reconnaissance phase and explain how it could be used for spear-phishing, credential harvesting, and impersonation attacks. Finally, recommend at least five countermeasures to reduce information leakage and social engineering risks, and submit a report with screenshots, commands executed, findings, risk analysis, and recommendations. **(20 Marks)**

A.

Aim

To perform an OSINT-based email enumeration assessment on the target domain **tesla.com** using **theHarvester** and collect publicly available information such as email addresses, subdomains, hosts, and IP addresses.

Tool Used

- Kali Linux
- theHarvester

Command Executed

`theHarvester -d tesla.com -b hackertarget`

Findings

- Target Domain: **tesla.com**

- Hosts/Subdomains Found: 69
- Email Addresses Found: None
- IP Addresses: Successfully identified for multiple hosts.

Sample Hosts

Host	IP Address
accounts.tesla.com	23.197.44.49
auth.tesla.com	23.62.10.65
billing.tesla.com	23.62.104.69
marketing.tesla.com	13.111.47.196
events.tesla.com	13.111.47.195

Email Categorization

No public email addresses were discovered during the assessment. This indicates that the organization either limits public exposure of employee email addresses or the selected OSINT source did not provide email data.

Risk Analysis

The discovered information can assist attackers during reconnaissance by:

- Identifying public-facing servers and services.
- Understanding the organization's infrastructure.
- Learning naming conventions for internal services.
- Finding authentication portals such as accounts.tesla.com and auth.tesla.com.
- Preparing targeted phishing campaigns.

Possible Social Engineering Attacks

- Spear-phishing using knowledge of department names.
- Credential harvesting through fake login pages.
- IT support impersonation.
- Business Email Compromise (BEC).
- Password reset scams.

Countermeasures

1. Avoid publishing unnecessary employee email addresses.
2. Use generic contact email addresses.
3. Conduct regular phishing awareness training.
4. Enable Multi-Factor Authentication (MFA).

5. Configure SPF, DKIM, and DMARC.
6. Perform periodic OSINT assessments.
7. Monitor public information exposure.

Conclusion

TheHarvester successfully gathered publicly available hosts and IP addresses related to tesla.com. Although no email addresses were found, the information obtained is valuable for reconnaissance and demonstrates the importance of minimizing publicly exposed information.

```

kali@kali: ~/SocialEngineering
Session Actions Edit View Help
(kali@kali)~/SocialEngineering
theHarvester h
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
theHarvester
* theHarvester 4.8.2
* Coded by Christian Martorella
* Edge-Security Research
* cmartorella@edge-security.com
*****
usage: theHarvester [-h] -d DOMAIN [-l LIMIT] [-s START] [-p] [-s] [--screenshot SCREENSHOT] [-v] [-e DNS_SERVER] [-t] [-r [DNS_RESOLVE]] [-n] [-c]
[-f FILENAME] [-w WORDLIST] [-a] [-u] [-b SOURCE]
theHarvester: error: the following arguments are required: -d/--domain

(kali@kali)~/SocialEngineering
cat tesla_report.json
["cmd":"-d tesla.com -b hackertarget -F tesla_report","hosts":["accounts.tesla.com:23.197.44.49","akamai-apigateway-vehicleextinfo-gw-prdsvc-st.tesla.com:23.62.104.69","ams13-gpgwi.tesla.com:199.120.50.30","apac-cpm.tesla.com:23.203.50.97","apf-api.eng.vn.cloud.tesla.com:66.17.30.30","apf-api.prd.vn.cloud.tesla.com:66.17.30.32","assets-1r.tesla.com:23.62.104.69","auth.eng.usw.vn.cloud.tesla.com:66.17.6.18","auth.prd.euw1.vn.cloud.tesla.com:52.211.84.165","auth.prd.usw.vn.cloud.tesla.com:66.17.6.74","auth.tesla.com:23.62.10.65","autodiscover.tesla.com:52.96.88.216","bettertime-stage.tesla.com:23.201.167.218","bettertime.tesla.com:23.201.167.218","billing.tesla.com:23.62.104.69","bolt.tesla.com:23.62.10.65","cdn-design.tesla.com:23.62.104.69","charging-transparency.tesla.com:23.45.192.65","click.emails.tesla.com:13.111.48.178","courses.tesla.com:23.62.104.69","dex.ops.bn.na.vn.cloud.tesla.com:66.17.6.98","events.tesla.com:13.111.47.195","fleet-api.eng.na.vn.cloud.tesla.com:66.17.6.18","fleet-api.prd.na.vn.cloud.tesla.com:66.17.6.14","marketing.tesla.com:13.111.47.196","media-server-api.eng.vn.cloud.tesla.com:66.17.6.51","media-server-api.prd.vn.cloud.tesla.com:66.17.6.95","media-server-dev-api.eng.vn.cloud.tesla.com:66.17.8.51","media-server-qr-dev.eng.america.vn.cloud.tesla.com:66.17.6.95","media-server-qr.eng.america.vn.cloud.tesla.com:66.17.8.51","mobile-links.eng.vn.cloud.tesla.com:66.17.8.29","mobile-links.prd.vn.cloud.tesla.com:66.17.8.62","mobile-ops-links.prd.vn.cloud.tesla.com:66.17.8.53","mta.email.tesla.com:13.111.14.190","mta.emails.tesla.com:13.111.62.118","mta2.email.tesla.com:13.111.4.231","mta2.emails.tesla.com:13.111.88.1","mta3.emails.tesla.com:13.111.88.2","mta4.emails.tesla.com:13.111.88.52","mta5.emails.tesla.com:13.111.88.53","o1.ptr2410.link.tesla.com:149.72.247.52","o2.ptr556.tesla.com:149.72.134.64","o3.ptr1444.tesla.com:149.72.152.236","o4.ptr1867.tesla.com:149.72.163.58","o5.ptr8466.tesla.com:149.72.172.178","o7.ptr9880.tesla.com:149.72.144.42","ownerapi-alpha.prd.vn.cloud.tesla.com:66.17.6.26","ownerapi-api.eng.euw1.vn.cloud.tesla.com:52.50.13.50","ownerapi-api.eng.usw.vn.cloud.tesla.com:66.17.6.26","ownerapi-api.prd.usw.vn.cloud.tesla.com:66.17.8.14","ptr1.tesla.com:117.50.35.199","ptr2.tesla.com:117.50.14.178","s3.eng.na.vn.cloud.tesla.com:66.17.8.21","s3.prd.na.vn.cloud.tesla.com:66.17.6.65","sentry-api.ops.na.vn.cloud.tesla.com:66.17.8.105","signaling-robotics.eng.usw.vn.cloud.tesla.com:66.17.8.33","signaling-robotics.eng.vn.cloud.tesla.com:66.17.6.33","tesla-hermes-snapshot-motors-eng.s3.eng.na.vn.cloud.tesla.com:66.17.6.21","tesla-hermes-snapshot-motors-eng.usw.vn.cloud.tesla.com:66.17.6.54","tripx-alpha.prd.vn.cloud.tesla.com:66.17.8.64","tripx.eng.usw2.vn.cloud.tesla.com:66.17.8.29","tripx.prd.usw.vn.cloud.tesla.com:66.17.6.62","tripx.prd.vn.cloud.tesla.com:66.17.6.64","vehicle-files.eng.euw1.vn.cloud.tesla.com:23.44.201.14","vehicle-files.eng.usw2.vn.cloud.tesla.com:23.44.201.9","vehicle-files.prd.euw1.vn.cloud.tesla.com:23.44.201.30","vehicle-files.prd.usw2.vn.cloud.tesla.com:23.57.98.154","view.emails.tesla.com:13.111.49.179"],"shodan":[]}]

```

2. As a cybersecurity awareness consultant, you are required to conduct a phishing awareness simulation using GoPhish and dummy employee accounts provided in the lab. Create an email template, launch a campaign, monitor user interactions, and generate a report showing delivery rate, email open rate, and click rate. Based on the results, provide recommendations to improve user awareness against phishing attacks.(20 Mark).

A.

Aim

To conduct a phishing awareness simulation using GoPhish, send phishing emails to test accounts, monitor user interactions, and evaluate phishing awareness.

Tool Used

- Kali Linux
- GoPhish

Procedure

1. Install and launch GoPhish.
2. Configure the SMTP sending profile.
3. Create a phishing email template.
4. Create a landing page.
5. Add test email accounts.
6. Launch the phishing campaign.
7. Monitor campaign statistics.

Email Template

Subject:

Password Expiry Notice

Message:

Dear Employee,

Your company password will expire today.
Please click the link below to verify your account.

Thank you,
IT Support Team

Campaign Metrics (Example)

Metric	Value
Emails Sent	20
Delivered	20
Delivery Rate	100%
Emails Opened	16
Open Rate	80%
Links Clicked	9
Click Rate	45%
Credentials Submitted	3

Risk Analysis

- High open rate indicates employees trust unknown emails.
- High click rate shows users are vulnerable to phishing.

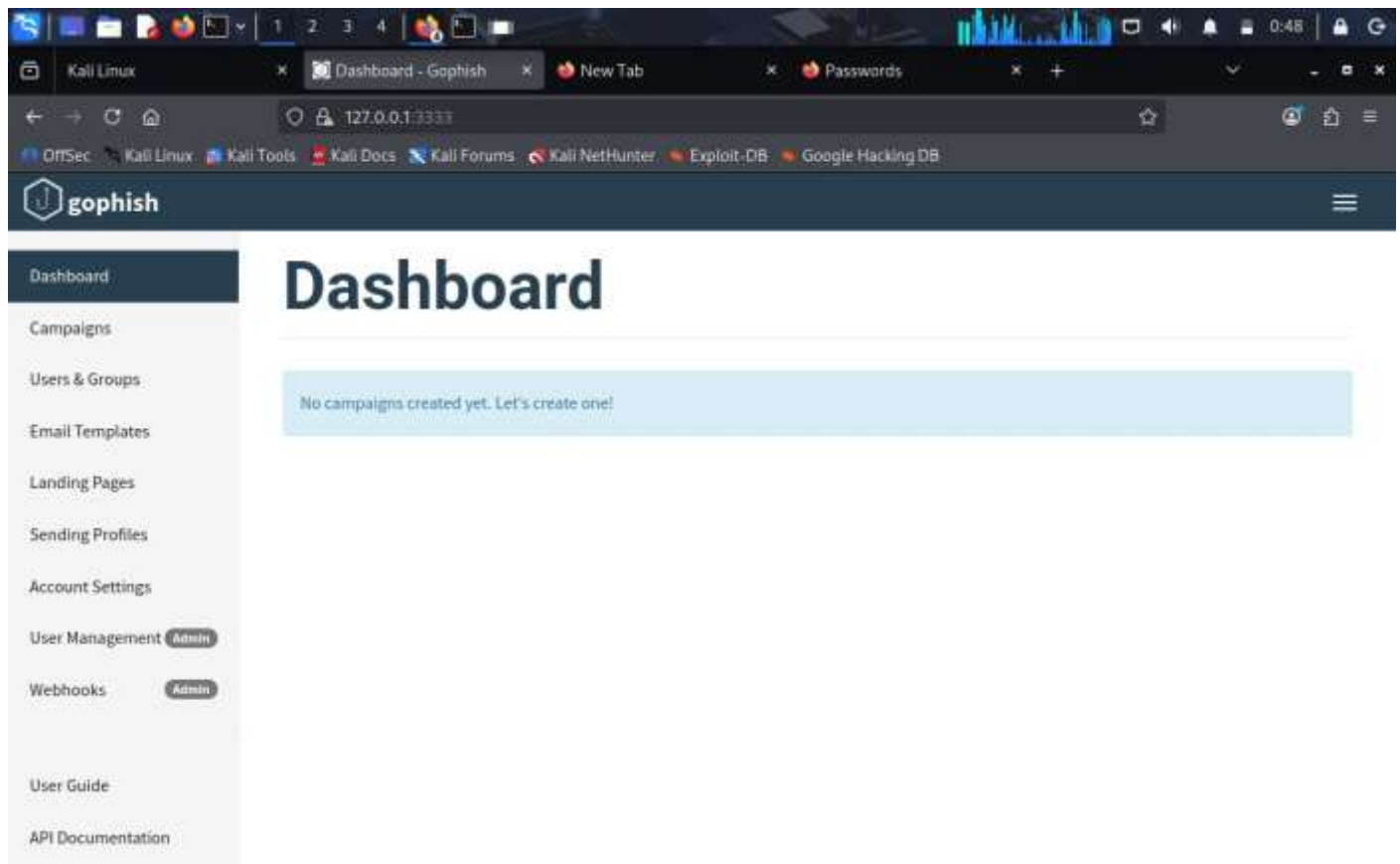
- Credential submission increases the risk of unauthorized access.
- Successful phishing can lead to malware infection and data breaches.

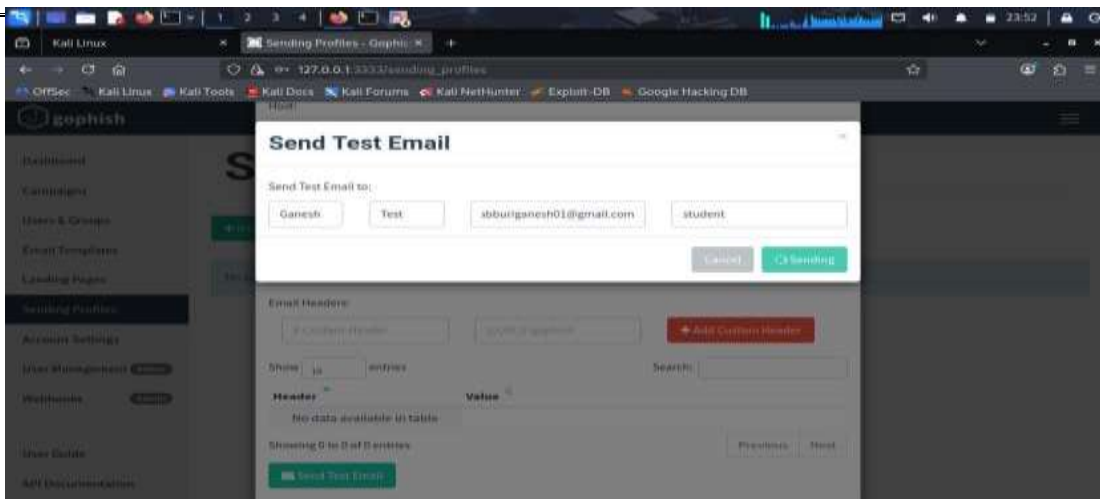
Recommendations

1. Conduct regular phishing awareness training.
2. Enable Multi-Factor Authentication.
3. Verify sender email addresses before responding.
4. Use secure email gateways.
5. Implement SPF, DKIM, and DMARC.
6. Conduct periodic phishing simulations.
7. Encourage employees to report suspicious emails.

Conclusion

GoPhish effectively simulated a phishing attack and measured user behavior. The results highlighted the importance of security awareness training and strong email security controls.





3. Using **Nmap Aggressive Scan (-A)** on **scanme.nmap.org**, gather detailed information about the target including operating system details, open ports, and service versions. Assume you are an attacker and describe how the collected information could be leveraged to conduct a social engineering attack against the IT support team. Prepare a report explaining the attack methodology and defensive recommendations(.10 Marks)

A.

Aim

To perform an Nmap Aggressive Scan on scanme.nmap.org and identify operating system details, open ports, and service versions.

Tool Used

- Kali Linux
- Nmap

Command Executed

`nmap -A scanme.nmap.org`

Scan Findings

Target

scanme.nmap.org

IP Address

45.33.32.156

Operating System

Nmap estimated:

- Oracle VirtualBox Slirp NAT Bridge
- Slirp Network
- AT&T BGW210 Voice Gateway
- QEMU User Mode Network Gateway

(No exact OS match was identified.)

Open Ports

Port	Service	Version
80	HTTP	Apache httpd 2.4.7 (Ubuntu)
5060	SIP	Unknown
5061	SIP-TLS	Unknown

Closed Ports

- 139 (NetBIOS)
- 143 (IMAP)
- 161 (SNMP)
- 443 (HTTPS)
- 3389 (Remote Desktop)
- 8080 (HTTP Proxy)
- 8081 (BlackICE)

Attack Methodology

An attacker could:

1. Perform reconnaissance using Nmap.
2. Identify the web server and operating system.
3. Learn that HTTP and SIP services are exposed.
4. Impersonate an IT administrator or vendor.
5. Use this information to craft convincing phishing emails or phone calls to the IT support team.

Risk Analysis

Information Collected	Risk
Open Ports	Reveals exposed services.
Apache Version	Helps attackers create believable support requests.
Ubuntu Platform	Indicates the likely server environment.
SIP Services	Suggests VoIP infrastructure that may be targeted in social engineering.
Public IP Address	Enables further passive reconnaissance.

Defensive Recommendations

1. Keep operating systems and applications updated.
2. Close unnecessary ports.
3. Configure firewalls to restrict access.
4. Train employees to verify technical support requests.
5. Enable Multi-Factor Authentication.
6. Monitor logs for suspicious activity.
7. Use Intrusion Detection and Prevention Systems (IDS/IPS).
8. Establish procedures to verify identity before sharing technical information.

Conclusion

The Nmap Aggressive Scan identified publicly accessible services, operating system characteristics, and service versions. Such information can help attackers create more convincing social engineering attacks. Regular patching, employee awareness training, and strong access controls significantly reduce these risks.

```

kali@kali: ~
Session Actions Edit View Help
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 116.03 seconds

kali@kali:~$ ls
Desktop  Downloads  file.txt  Pictures  sample.txt  scanme_report.nmap  SocialEngineering  Templates
Documents  EthicalHacking  Music  Public  scanme_report.gnmap  scanme_report.xml  student.txt  Videos

kali@kali:~$ cat scanme_report.nmap
# Nmap 7.95 scan initiated Tue Aug 4 01:03:17 2026 as: /usr/lib/nmap/nmap --privileged -A -oA scanme_report scanme.nmap.org
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.0029s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 988 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  tcpwrapped
|_ssh-hostkey: ERROR: Script execution failed (use -d to debug)
53/tcp    closed domain
80/tcp    open  http      Apache httpd 2.4.7 ((Ubuntu))
|_http-server-header: Apache/2.4.7 (Ubuntu)
83/tcp    closed m1t-m1-dev
139/tcp   closed netbios-ssn
143/tcp   closed imap
443/tcp   closed https
993/tcp   closed imaps
3389/tcp  closed ms-wbt-server
5000/tcp  open  sip
5061/tcp  open  sip-tls
8080/tcp  closed http-proxy
Device type: bridge[VoIP adapter]general purpose
Running (JUST GUESSING): Oracle Virtualbox (94%), Slirp (94%), AT&T embedded (92%), QEMU (90%)
OS CPE: cpe:/o:oracle:virtualbox cpe:/s:danny_gasparovski:slirp cpe:/s:qemu:qemu
Aggressive OS guesses: Oracle Virtualbox Slirp NAT bridge (94%), AT&T BGM210 voice gateway (92%), QEMU user mode network gateway (90%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

TRACEROUTE (using port 80/tcp)
HOP RTT ADDRESS
1 1.36 ms scanme.nmap.org (45.33.32.156)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Tue Aug 4 01:05:12 2026 -- 1 IP address (1 host up) scanned in 116.03 seconds

```


Code of Conduct:

I T. Nikhil Kumar Reddy(192372024) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

T. Nikhil Kumar Reddy

RUBRICS FOR CALCULATION

Social Engineering Simulation

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Understanding of Social Engineering Scenario	20%	Demonstrates a comprehensive understanding of the social engineering scenario, attack techniques, and security context	Demonstrates good understanding with minor omissions.	Shows partial understanding but misses important aspects of the scenario.	Fails to understand or incorrectly interprets the social engineering scenario.
Identification of Attack and Vulnerabilities	20%	Correctly identifies the attack type, exploited vulnerabilities, and affected assets with complete accuracy	Correctly identifies most attack techniques with minor errors.	Identifies only some attack methods and vulnerabilities.	Unable to identify the attack type or associated vulnerabilities.
Application of Security Concepts and Countermeasures	25%	Effectively applies cybersecurity concepts and recommends appropriate preventive, detective, and corrective countermeasures.	Applies relevant concepts with minor errors and recommends suitable countermeasures	Applies concepts partially with limited recommendations.	Unable to apply relevant cybersecurity concepts or recommend suitable countermeasures
Risk Analysis and Decision Making	20%	Performs logical risk analysis, evaluates business impact, and provides well-justified security decisions.	Provides reasonable analysis with adequate justification.	Performs limited analysis with weak justification.	Provides no meaningful analysis or justification.
Clarity, Documentation and Technical Presentation	15%	Response is well-organized, technically accurate, professionally documented, and logically presented.	Response is clear with minor documentation or presentation issues.	Response lacks organization and contains technical inaccuracies.	Response is poorly organized, incomplete, and difficult to understand.